Informe M0

Arrencada i model d’amenaces

Course: 2026/2027

Membres: Nicolau Mesalles, Óscar Saborido Valdés, Hamza El Haddad Sabri

Professor: Eduard Lara

Repositori: https://github.com/NicolauMesalles/sbd-videojocs

TAULA DE CONTINGUTS

1. Resum 3
2. Repartiment de la feina 3
3. Desenvolupament 3
4. Evidències 9
5. Problemes trobats i com es van resoldre 11
6. Riscos pendents 12

1. Resum

Hem escollit el cas 4, una plataforma de videojocs en línia: els jugadors compren monedes amb diners reals, les gasten en objectes, xategen i denuncien missatges. Hem muntat un esquema de 10 taules amb 13 FK, CHECK i triggers per als menors de 14 anys, i l'hem omplert amb 6.560 files sintètiques de Faker. Un sol docker compose up -d aixeca l'entorn des de zero. El model d'amenaces valora 17 actius i 15 riscos: 3 crítics, 6 alts i 6 mitjans.

2. Repartiment de la feina

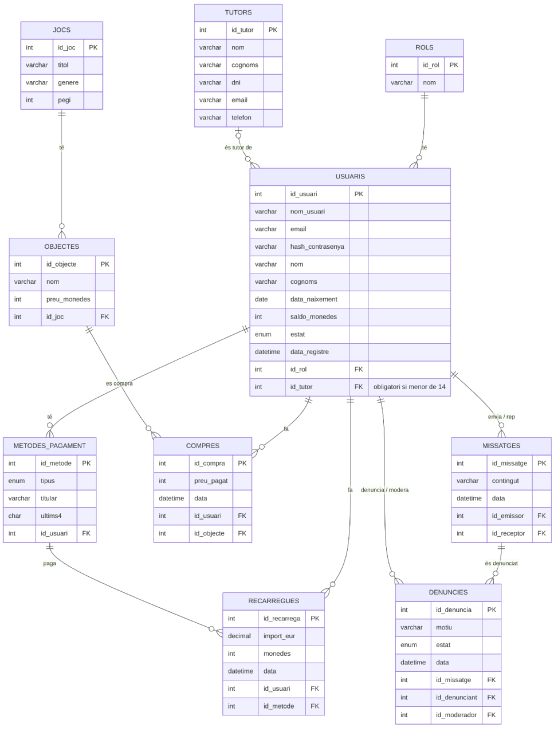
Membre	Tasques	Commits principals
Nicolau	Repositori i branques, compose.yml, .env.example, .gitignore, README, servei app, model d'amenaces, informe	50046db, a474580, 86a4d1e, ffa9737
Óscar	Diagrama E-R, esquema SQL (taules, FK, CHECK, triggers)	c55bd1d, 8ff6d7b
Hamza	Scripts Faker de dades sintètiques, càlcul de saldos, càrrega de tota la carpeta db/, informe	9308fcf, 3158ef0

3. Desenvolupament

3.1 Grup i cas de negoci

Decisió: cas 4, plataforma de videojocs. **Justificació:** la banca en línia té un model pla (comptes i moviments) amb un sol tipus de dada sensible. La plataforma de videojocs, en canvi, reuneix quatre fonts de risc: diners reals, una moneda virtual, el saldo de la qual és un actiu d'integritat pur. Comunicacions privades que s'han de poder moderar, i menors, que per sota dels 14 anys necessiten el consentiment del tutor.

3.2 Model entitat-relació i esquema



Decisió. plataforma_jocs té 10 taules en tres blocs: comptes (rols, tutors, usuaris), economia (jocs, objectes, metodes_pagament, recarregues, compres) i xat (missatges, denuncies). Els diners van en dos passos: primer es compren monedes amb euros (recarregues) i després es gasten en objectes (compres).

Justificació.

- **rols és una taula pròpia** i es carrega amb l'esquema, perquè no són dades de prova.
- **compres resol la relació N:M** usuaris–objectes i guarda preu_pagat, perquè una compra antiga conservi el preu real encara que el catàleg canviï.
- **Targetes:** no es guarda ni el PAN ni el CVV, només ultims4. PCI DSS prohibeix el CVV, i el PAN el té la passarel·la.
- **Contrasenyes:** mai en clar, només a hash_contrasenya (VARCHAR(255), prou per a bcrypt o Argon2). A les dades de prova el valor és fake.sha256(), el SHA-256 d'un nombre aleatori i no el hash de cap contrasenya: només omple el camp amb el format correcte. L'algorisme real es decideix a M3.
- **Imports:** en DECIMAL(6,2), perquè FLOAT arrodoneix.
- **Sense cascada:** les FK són RESTRICT, perquè l'historial de pagaments s'ha de conservar. Donar de baixa un compte vol dir canviar-ne l'estat.
- **Menors de 14 anys:** necessiten tutor. Ho controlen dos triggers, perquè MySQL no admet CURDATE() dins d'un CHECK. El d'UPDATE impedeix treure el tutor després de crear el compte.

```
CREATE TRIGGER comprovar_tutor_update
BEFORE UPDATE ON usuaris
FOR EACH ROW
BEGIN
  IF TIMESTAMPDIFF(YEAR, NEW.data_naixement, CURDATE()) < 14 AND NEW.id_tutor IS NULL THEN
    SIGNAL SQLSTATE '45000' SET MESSAGE_TEXT = 'Un menor de 14 anys necessita tutor';
  END IF;
END //
```

Altres restriccions: CHECK de saldo_monedes >= 0, de pegi IN (3,7,12,16,18) i de preu_monedes/import_eur > 0. Perfils: **administrador** (gestiona tota la plataforma) · **moderador** (revisa denúncies i missatges denunciats) · **auditor** (consulta sense modificar) · **jugador** (només accedeix a les seves dades).

3.3 Entorn amb Docker Compose

Decisió. Dos serveis:

- **app** (python:3.12-slim, contenidor filler) instal·la Faker==40.43.0, executa els scripts d'app/, escriu els .sql a db/ i acaba amb Exited (0). No té restart. Porta TZ: UTC perquè Faker calcula dates amb l'hora local i, sense fixar-la, cada màquina generaria dades diferents.
- **db** (mysql:8.4, contenidor BBDD_Videojocs) només arrenca quan app acaba bé. Munta ./db a initdb.d, on l'entrypoint executa els fitxers per ordre alfabètic (01_ → 11_), i persisteix les dades al volum db_data.

Justificació de seguretat. El port només s'exposa a 127.0.0.1. Les credencials són a .env, que és al .gitignore; al repositori només hi ha .env.example. El codi es munta :ro. Els scripts d'initdb.d només s'executen amb el volum buit: per recarregar cal down -v.

Pendent: les imatges i Faker es fixen per etiqueta o versió, no per *digest* o hash (--require-hashes). Un paquet manipulat a PyPI s'executaria a cada up.

```
ports:
  - "127.0.0.1:3306:3306"
volumes:
  - ./db:/docker-entrypoint-initdb.d:ro
depends_on:
  app:
    condition: service_completed_successfully
```

3.4 Dades sintètiques

Decisió. Hi ha un script per taula, amb Faker es_ES i llavor fixa, que escriu un INSERT al seu .sql. Els scripts no es connecten a MySQL. El prefix 02_–11_ fa que l'ordre alfabètic segueixi les FK.

Taula	Files	Script → fitxer	Obtingudes
tutors	40	generar_dades.py → 02_tutors.sql	40
usuaris	500	gen_usuaris.py → 03_usuaris.sql	500
jocs	20	gen_jocs.py → 04_jocs.sql	20
objectes	100	gen_objectes.py → 05_objectes.sql	100
metodes_pagament	400	gen_metodes.py → 06_metodes_pagament.sql	400
recarregues	800	gen_recarregues.py → 07_recarregues.sql	800
compres	1.500	gen_compres.py → 08_compres.sql	1.500
missatges	3.000	gen_missatges.py → 09_missatges.sql	3.000
denuncies	200	gen_denuncies.py → 10_denuncies.sql	200
(saldos)	—	escrit a mà → 11_saldos.sql	—

Justificació.

- **Reproduïbilitat.** Llavors fixes i dates fixes (fins al 17/10/2026), no "avui". Com que app regenera els .sql a cada up, la reproduïbilitat depèn de Faker==40.43.0 i TZ: UTC. Un canvi de versió ja va modificar 03_usuaris, 07_recarregues i 09_missatges.
- **Usuaris.** 2 administradors (ids 1–2), 8 moderadors (3–10), 2 auditors (11–12) i 488 jugadors. Els ids 441–500 són menors de 8 a 12 anys amb un dels 40 tutors. Els adults neixen entre el 1966 i el 2008.
- **Pagaments.** Tenen mitjà de pagament 400 dels 428 jugadors adults (ids 13–412). Els menors no en tenen, i de les targetes només hi ha ultims4. Les recàrregues són de 5, 10, 20 o 50 € (1 € = 100 monedes), i cada mitjà en té almenys una.
- **Compres.** Es fan amb INSERT … SELECT: MySQL llegeix el preu i el saldo disponible i només insereix si hi cap, sempre després de l'última recàrrega. Es fan 2.200 intents i es conserven les 1.500 primeres compres acceptades.
- **Saldo.** No s'inventa: 11_saldos.sql calcula recàrregues − compres i s'executa l'últim.
- **Xat.** L'emissor sempre és diferent del receptor, i denuncia qui rep el missatge. El 70 % de les denúncies estan resoltes i tenen un moderador (ids 3–10).

3.5 Classificació de les dades per sensibilitat

Hi ha dues valoracions independents:

- **Sensibilitat**, és a dir, qui ho pot veure. *Públic:* qualsevol visitant. *Intern:* personal i aplicació. *Confidencial:* dades personals, financeres o de comunicació. Només el titular i els rols autoritzats; una filtració s'ha de notificar segons el RGPD. *Restringit:* la filtració compromet el sistema o la identitat de tercers. Accés mínim i nominal.
- **Impacte C/I/A de 0 a 9:** 0 = cap efecte; 2 = molèstia menor, sense dades personals; 5 = pocs usuaris o recuperable; 7 = dades de molts usuaris, frau o sanció; 9 = compromís total, dany irreversible o dany a menors.
- **Nivell:** és la mitjana de C, I i A: < 3 BAIX, de 3 a < 6 MITJÀ, ≥ 6 ALT.

#	Actiu	Components	Sensibilitat	C	I	A	Mitj.	Nivell
1	Servidor / contenidor MySQL	Motor de BD i contenidor	Restringit	9	9	9	9,0	ALT
2	Credencials d'accés	Email, hash de contrasenya	Restringit	9	9	9	9,0	ALT
3	Còpies de seguretat	backup/ i dumps	Restringit	9	9	7	8,3	ALT
4	Secrets d'infraestructura	.env, root, credencials de l'app	Restringit	9	7	7	7,7	ALT
5	Dades de tutors	Nom, cognoms, DNI, email, telèfon	Restringit	9	7	5	7,0	ALT
6	Control parental	Data de naixement, vincle amb el tutor	Confidencial	7	9	5	7,0	ALT
7	Mitjans de pagament	Tipus, titular, últims 4 dígits	Confidencial	6	7	7	6,7	ALT
8	Recàrregues	Import en €, monedes, data, mètode	Confidencial	6	9	5	6,7	ALT
9	Inventari i compres	Objecte, preu pagat, data	Confidencial	6	7	7	6,7	ALT
10	Comunicacions privades	Missatge, emissor, receptor, data	Confidencial	7	7	5	6,3	ALT
11	Denúncies i moderació	Motiu, estat, denunciant, moderador	Confidencial	7	7	5	6,3	ALT
12	Control d'accés	Rols, rol assignat, estat del compte	Intern	2	9	7	6,0	ALT
13	Moneder virtual	Saldo de monedes	Intern	2	9	7	6,0	ALT
14	Dades personals	Nom, cognoms, data de registre	Confidencial	6	5	5	5,3	MITJÀ
15	Catàleg d'objectes	Nom, preu, joc	Públic	0	7	5	4,0	MITJÀ
16	Catàleg de jocs	Títol, gènere, PEGI	Públic	0	7	5	4,0	MITJÀ
17	Perfil públic	Nom d'usuari	Públic	0	5	5	3,3	MITJÀ

Els dos eixos són independents. La sensibilitat només mesura la confidencialitat; el nivell mesura què es perd si s'ataca qualsevol de les tres dimensions. Per això el control d'accés i el moneder són *Intern* (C = 2) però tenen nivell ALT: canviar un id_rol o un saldo_monedes no filtra res, però dona privilegis o diners. I un catàleg *Públic* és MITJÀ, perquè un preu alterat també és frau. Les categories de l'esquema (personals, financeres i comunicacions) són una agrupació dins d'aquests nivells, no una alternativa.

3.6 Model d'amenaces

Probabilitat (P), de 0 a 9, avaluada sobre l'estat de M0: 0 = impossible; 1–2 = calen diverses condicions i un atacant avançat; 3–4 = cal accés previ al host, o un error que un control existent ja dificulta; 5–6 = n'hi ha prou amb un error o una fallada de l'app, i no hi ha cap control; 7–8 = trivial o habitual, sense control; 9 = gairebé segur.

Impacte (I): és el valor de l'actiu a la dimensió atacada, no la mitjana (R01 ataca la I del #6, per tant I = 9).

Risc = P × I, de 0 a 81: **CRÍTIC ≥ 49:** és el risc de P = 7 i I = 7, i també s'hi arriba amb P = 6 i I = 9 (R05). **ALT, de 35 a 48:** com a mínim, una amenaça possible (5) sobre un impacte alt (7). **MITJÀ, de 15 a 34. BAIX < 15.**

ID	Actiu	Amenaça	Agent	CIA	P	I	Risc
R01	#6	Un menor es registra amb una data de naixement falsa, o la canvia després, per constar com a major de 14 anys i desfer el vincle amb el tutor	Menor	I	8	9	CRÍTIC 72
R05	#13	Un jugador fa servir una petició manipulada o una SQLi per augmentar el seu saldo_monedes, aprofitant que l'usuari de l'app té tots els privilegis	Jugador	I	6	9	CRÍTIC 54
R06	#10	Un moderador llegeix converses sense que hi hagi denúncia, perquè res no limita el seu accés només als missatges denunciats	Insider	C	7	7	CRÍTIC 49
R03	#3	Un dump .sql sense xifrar desat a backup/ acaba en un commit, perquè el .gitignore no exclou la carpeta, i exposa tots els actius alhora	Error humà	C	5	9	ALT 45
R07	#1	Un down -v, l'esborrat del volum o una fallada de disc eliminen la BD	Fallada / error	A	5	9	ALT 45
R08	#12	Un empleat amb accés a la BD s'assigna el rol d'administrador o desbandeja un compte canviant id_rol o estat	Insider	I	5	9	ALT 45
R10	#8	Una correcció manual sense registre descuadra import_eur i monedes respecte de la passarel·la	Error humà	I	5	9	ALT 45
R12	#9	Compres concurrents (*race condition*) aconsegueixen objectes sense que es descompti el saldo	Jugador	I	5	7	ALT 35
R13	#6	Una API que retorna l'usuari sencer exposa data_naixement, i un adult hi identifica menors per contactar-los pel xat	Adult	C	5	7	ALT 35
R11	#3	Un ransomware xifra la BD i les còpies, que són al mateix host	Extern	A	4	7	MITJÀ 28
R14	#11	L'autor d'un missatge denunciat n'edita el contingut, o esborra els missatges abans que els denunciïn, i el moderador ja no troba la prova	Adult	I	4	7	MITJÀ 28

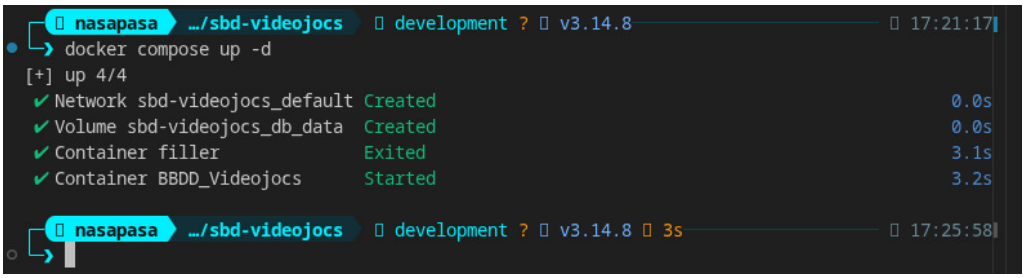
ID	Actiu	Amenaça	Agent	CIA	P	I	Risc
R02	#4	El .env amb la contrasenya root arriba al repositori (per un git add -f, per valors reals a .env.example o perquè el repositori es fa públic)	Error humà	C	3	9	MITJÀ 27
R04	#2	Un malware o un usuari local connecta a 127.0.0.1:3306, bolca emails i hashes i els intenta crackejar offline	Local	C	3	9	MITJÀ 27
R09	#5	Un agent amb accés al host extreu el DNI, el telèfon i el nom dels tutors per suplantar-los o vendre'ls	Local	C	3	9	MITJÀ 27
R15	#7	Amb el titular i els últims 4 dígits filtrats, un atacant fa un phishing creïble ("la targeta acabada en 4417…")	Extern	C	4	6	MITJÀ 24

Justificació de P.

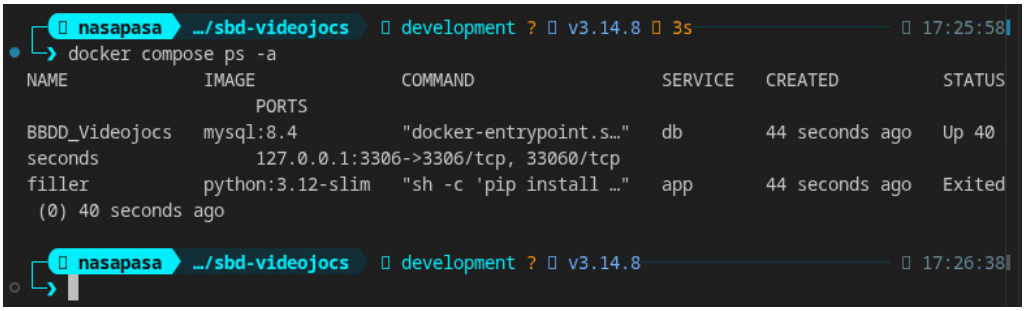
- **R01:** mentir en el registre és trivial i la BD no ho pot verificar. A més, comprovar_tutor_update (01_schema.sql:136) només mira NEW: frena treure el tutor mentre la data diu que és menor, però no si primer es canvia data_naixement, o si es canvien les dues columnes en el mateix UPDATE. Cal fer data_naixement immutable per als jugadors.
- **R05:** l'app encara no existeix. S'avalua suposant que farà servir el MYSQL_USER de M0, que té GRANT ALL PRIVILEGES ON plataforma_jocs.* (és el que fa la imatge oficial de MySQL amb MYSQL_USER/MYSQL_DATABASE, i amb host '%'). Qualsevol fallada de l'app donaria UPDATE, DELETE, DROP i ALTER lliures.
- **R03:** els db/*.sql es pugen a propòsit, així que no es pot ignorar *.sql. Cal ignorar backup/* (excepte .gitkeep). No arriba a 7 perquè el repositori és privat.
- **R06:** sense vistes, qui accedeix a missatges la veu sencera. **R07:** en desenvolupament passa sovint, però requereix un error concret. **R08:** requereix un insider, i no hi ha cap auditoria que el dissuadeixi. **R10:** les correccions manuals són habituals i no deixen rastre. **R12:** depèn que l'app no faci servir transaccions ni bloquejos. **R13:** depèn de quins camps retorni l'app. **R11:** requereix comprometre el host, però el dany seria total perquè les còpies no estan separades.
- **R14:** la FK denuncies → missatges és RESTRICT: un missatge denunciat no es pot esborrar, però sí editar, i un de no denunciat es pot esborrar. Depèn que l'app permeti editar o esborrar missatges.
- **R02:** mitigat pel .gitignore i pel repositori privat. Falta un escaneig de secrets (hook de pre-commit amb gitleaks).
- **R04:** el bind a 127.0.0.1 el limita a un agent que ja sigui al host. Amb les dades de prova el crackeig no obté res (els hashes són aleatoris); el risc es valora sobre el disseny, en què un hash ràpid sense sal seria viable. Els emails es filtren igualment.
- **R09:** mateix vector i mateix control que R04. **R15:** requereix una filtració prèvia i enginyeria social, i sense el PAN la dada filtrada és limitada.

4. Evidències

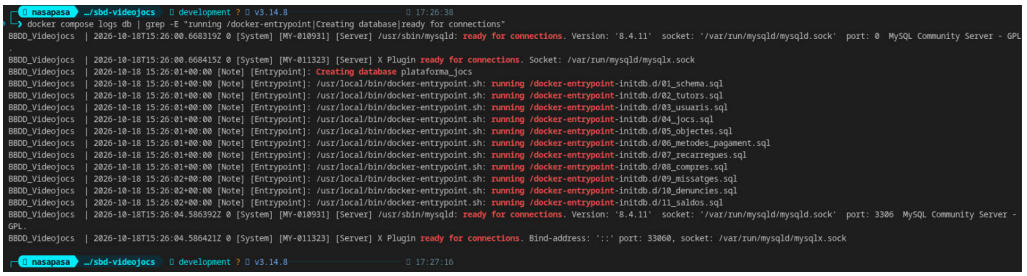
1. docker compose down -v && docker compose up -d: l'entorn arrenca des de zero.



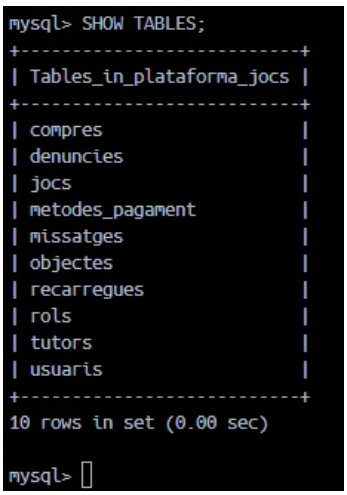
2. docker compose ps -a: filler acaba amb Exited (0) i BBDD_Videojocs és Up.

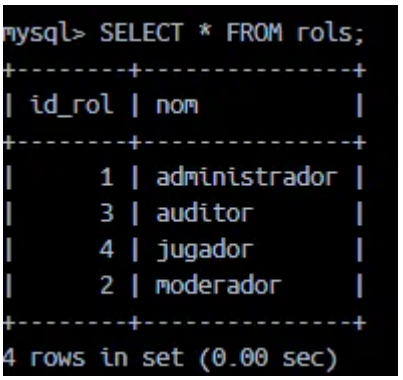


3. docker compose logs db: apareixen les línies running /docker-entrypoint-initdb.d/01_schema.sql … 11_saldos.sql.



4. SHOW TABLES; mostra les 10 taules, i SELECT * FROM rols; els 4 perfils.

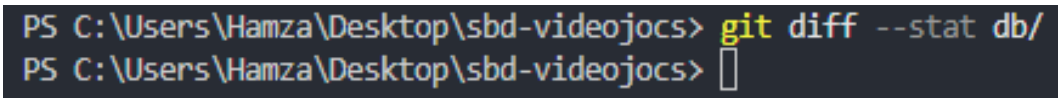




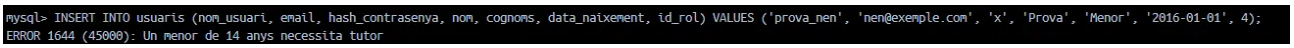
5. COUNT(*) per taula coincideix amb la columna “Obtingudes” de 3.4 (9 de 9). SELECT MIN(saldo_monedes) FROM usuaris; retorna 0.



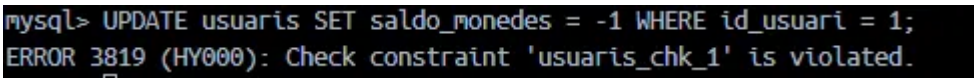
6. git diff --stat db/ surt buit després de l’up: les dades són reproduïbles.



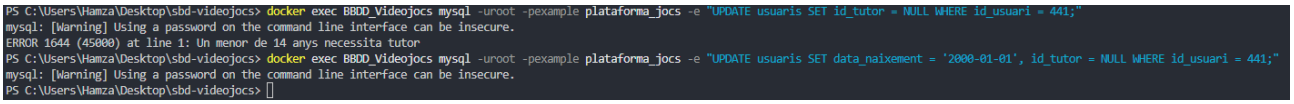
7. Un INSERT d’un menor de 14 anys sense tutor dona ERROR 1644.



8. UPDATE usuaris SET saldo_monedes = -1 … dona ERROR 3819 (CHECK).



9. UPDATE usuaris SET id_tutor = NULL WHERE id_usuari = 441; falla, però … SET data_naixement = '2000-01-01', id_tutor = NULL … funciona: és R01.



5. Problemes trobats i com es van resoldre

Problema	Causa	Solució
Error en crear usuaris (Óscar)	MySQL no admet CURDATE() dins d'un CHECK	Dos triggers, un per a INSERT i un per a UPDATE
Ordre de càrrega (Óscar)	initdb.d s'executa per ordre alfabètic	01_schema.sql i dades de 02_ a 11_
DNI diferents a cada execució (Hamza)	nif() fa servir l'atzar de Python, no el de Faker	DNI calculat a mà (mòdul 23 → lletra) amb el generador amb llavor
Telèfons rebutjats (Hamza)	Faker en genera de fins a 16 caràcters i la columna és VARCHAR(15)	Mòbils de 9 dígits
Risc de saldo negatiu (Hamza)	Compres a l'atzar superarien les recàrregues	INSERT … SELECT condicionat al saldo
Càrrega manual a mitges (Hamza)	MySQL encara no acceptava connexions	Carregar via initdb.d, que s'executa abans d'obrir el port
El compose no arrencava (Nicolau)	container_name: buit	BBDD_Videojocs i filler
L'esquema no es carregava (Nicolau)	Es muntava db/schema.sql, que no existeix; Docker crea un directori buit en lloc del fitxer	Muntar 01_schema.sql i, després, tot ./db
BD de l'app equivocada (Nicolau)	.env.example deia MYSQL_DATABASE=example, però l'esquema crea plataforma_jocs	MYSQL_DATABASE=plataforma_jocs
app en bucle (Nicolau)	restart: always el tornava a arrencar cada vegada que acabava	Sense restart; db en depèn amb service_completed_successfully
Els canvis no es carregaven (tots)	initdb.d només s'executa amb el volum buit	docker compose down -v
Tres .sql canviats sense tocar cap script (Nicolau)	Una altra versió de Faker o una altra zona horària	Faker==40.43.0 i TZ: UTC

6. Riscos pendents

Risc	Fita
Comprar no resta el saldo automàticament, i compres concurrents se salten el control (R12). Cal una transacció amb l'aïllament adequat i ROLLBACK si falla.	M1
Tots els perfils veuen totes les columnes i files. Calen vistes: el moderador només ha de veure els missatges denunciats (R06), i data_naixement no s'ha d'exposar (R13).	M1
L'usuari de l'app té ALL PRIVILEGES (R05), i qualsevol usuari amb accés pot canviar id_rol, estat (R08) o data_naixement (R01). Cal RBAC, privilegis per columna i deixar d'usar root.	M2
No hi ha registre de qui canvia el saldo o els imports (R08, R10). L'auditoria nativa és a M4, però en un altre motor; a MySQL caldria una taula de log amb triggers, i cap fita no ho cobreix.	M4 (sense cobertura a MySQL)
Res no impedeix pagar amb el mètode d'un altre usuari ni comprar objectes de jocs amb un PEGI superior a l'edat.	M3, a l'aplicació
El DNI dels tutors i el titular de la targeta són en clar. Calen bcrypt o Argon2 amb sal i consultes parametritzades (R05).	M3
Les còpies han d'estar fora del host i del repositori (R03, R11), i cal una recuperació provada (R07).	M4